

EPI Quantum Crypto team
Cryptographie appliquée et évaluation des sources d'entropie

GUIDE DE BONNES PRATIQUES · VERSION 4.1

libsp80090b : l'évaluation d'entropie en pratique

Bonnes pratiques de SP 800-90B à travers les 18 cas des labs, le redémarrage et le conditionnement

RÉFÉRENCE	NT-03
OBJET	Maîtriser l'évaluation de la min-entropie d'une source de bruit avec libsp80090b
VERSION	4.1 — septembre 2026
AUTEURS	EPI Quantum Crypto team
DIFFUSION	Guide de bonnes pratiques — diffusion publique
RÉFÉRENTIELS	NIST SP 800-90B ; SP 800-90C ; FIPS 140-3 IG D.K
DOCUMENTS LIÉS	NT-01 Note technique (méthode) ; NT-02 Guide d'utilisation (API et labs) ; version anglaise : NT-03 (en)
REMPLACE	NT-03 v4.0

RÉSUMÉ

Ce guide de niveau master enseigne l'évaluation de la min-entropie d'une source de bruit selon **NIST SP 800-90B** [1], avec **libsp80090b**, à travers les **18 cas** que produit `lab/gen_data.sh` : sources saines, défauts de conception, effets d'environnement, pannes et sorties de générateurs déterministes. Chaque source physique y est simulée par un modèle dont l'entropie est connue : on peut donc confronter chaque mesure à la vérité, ce qu'aucune source réelle ne permet. Les labs 3 et 4 complètent les 18 cas par le test de redémarrage et le conditionnement.

Les résultats tiennent en sept règles. Les tests statistiques ne voient pas le déterminisme : un AES à clé nulle obtient 7,87 bits sur 8. Une source IID peut être pauvre : l'écrêtage d'un CAN détruit 66 % de l'entropie sans créer de dépendance. Une estimation peut dépasser la vérité : 3,43 bits mesurés pour 3,33 réels sous un parasite secteur, d'où la revendication du modèle comme plafond. Une moyenne cache le pire cas : 3,38 bits crédités pour une source qui finit à 2,38. Enfin, seul le test de redémarrage voit une source qui repart toujours des mêmes valeurs. Le guide se termine par un protocole de qualification en huit étapes, un exemple chiffré complet et l'explication des temps de calcul : le test 1 peut durer une heure par fichier, à cause de 10 000 compressions bzip2 que seul un échec impose jusqu'au bout.

Mots-clés : libsp80090b ; min-entropie ; bonnes pratiques ; voie IID ; voie non IID ; redémarrage ; conditionnement ; tests de santé ; gen_data.sh ; labs

Sommaire

1 Objet et mode d'emploi 4
2 Sept règles d'or 4
3 Carte des 18 cas 5
4 Analyse des cas 6
4.1 Lire une sortie du lab 2 6
4.2 Sources saines : la référence (cas 1 à 3) 6
4.3 Défauts de conception (cas 4 à 8) 6
4.4 Environnement et non-stationnarité (cas 9 à 11) 7
4.5 Pannes franches (cas 12 et 13) 7
4.6 Sorties conditionnées : le piège (cas 14 à 18) 8
5 Redémarrage et conditionnement 8
5.1 Lab 3 : le test de redémarrage 8
5.2 Lab 4 : conditionnement et pleine entropie 9
6 Protocole de qualification 9
7 Erreurs fréquentes 11
8 Temps de calcul 11
8.1 Pourquoi le test 1 est long 12
8.2 Pourquoi les autres tests sont rapides 13
8.3 Conséquences pratiques 13
9 Limites de l'outil à connaître 14
10 Conclusion 14
11 Références 14

1 Objet et mode d'emploi

Ce guide s'adresse aux évaluateurs, aux cryptographes et aux ingénieurs qui qualifient une source d'entropie. Il suppose connue la méthode de SP 800-90B (NT-01) et l'emploi de l'API et des labs (NT-02). Il ne compare pas la bibliothèque à l'outil du NIST : cette conformité est vérifiée à part par `make check` (NT-02). Il répond à une autre question : **que faut-il conclure, et que faut-il faire, devant chaque résultat ?**

Tableau 1. Les quatre labs et la question que chacun pose.

Lab	Test (SP 800-90B)	Programme	Question posée
1	Voie IID (§5)	`lab/lab1.sh`	Les échantillons sont-ils indépendants et de même loi ? Si oui, $H_{original}$ vient du seul estimateur de la valeur la plus fréquente (MCV).
2	Voie non IID (§6)	`lab/lab2.sh`	Quelle entropie reste-t-il face aux dix estimateurs, dont les prédicteurs ? $H_I = \min(H_{original}, n \times H_{bitstring})$.
3	Redémarrage (§3.1.4)	`lab/lab3.sh`	La source repart-elle d'un état imprévisible à chaque mise sous tension ?
4	Conditionnement (§3.1.5)	`lab/lab4.sh`	Combien d'entropie sort d'une fonction de conditionnement, et à quelle condition la sortie est-elle pleine ?

Les données viennent de `lab/gen_data.sh all --seed 90` : 10^6 échantillons par fichier, 1 000 × 1 000 pour le redémarrage. Les résultats sont dans `lab/results/labN_*/<cas>.res`, une ligne de synthèse par cas dans `labN.log`.

> **Lire les chiffres.** Une autre graine change les estimations vers la troisième décimale, et peut inverser un verdict IID proche du seuil (cas 3 et 17). Les conclusions de ce guide ne dépendent pas de ces décimales.

2 Sept règles d'or

Chaque règle est démontrée par au moins un des cas de la section 4.

1. **Évaluer le bruit brut, jamais une sortie conditionnée.** Un DRBG ou un hachage passe tous les tests, même sans aucune entropie (cas 14 à 18). La capture se fait en amont de toute fonction déterministe.
2. **Le modèle physique d'abord, la mesure ensuite.** Les tests sont une vérification boîte noire. Une estimation peut dépasser l'entropie réelle (cas 8) : la revendication H_{claim} du modèle sert de plafond.
3. **La voie IID se mérite.** Il faut un argument physique **et** les trois tests réussis. Un seul test rejeté suffit à imposer la voie non IID (cas 3), et l'on ne relance pas une capture jusqu'à obtenir un succès (cas 17).
4. **IID ne veut pas dire bonne source.** Une source écrêtée ou biaisée est IID et pauvre (cas 4 et 7). Regarder l'histogramme avant les verdicts.
5. **Une campagne par condition, retenir le pire cas.** Un fichier qui mélange des régimes donne une moyenne, pas le pire cas (cas 9 à 11). Capturer séparément chaque température, tension et état de vieillissement.
6. **Tester le démarrage.** Une source saine en régime établi peut repartir des mêmes valeurs à chaque mise sous tension ; seul le test de redémarrage le voit (lab 3).
7. **Appliquer la règle du minimum, puis dimensionner.** $H = \min(H_{claim}, H_I, H_r, H_c)$; de H découlent la graine, les seuils des tests de santé et la marge de conditionnement (section 6).

3 Carte des 18 cas

Le tableau 2 résume les 18 cas des labs 1 et 2, dans l'ordre de `gen_data.sh --list`. La colonne « H attendue » est la min-entropie par échantillon que donne le modèle ; le lab 1 donne le verdict IID et, entre parenthèses, $H_{original}$, qui n'est utilisable que si le verdict est IID.

Tableau 2. Les 18 cas : modèle, entropie attendue et résultats des labs 1 et 2.

N°	Jeu	Bits	Modèle (`gen_data.sh`)	H attendue	Lab 1 : verdict ($H_{original}$)	Lab 2 : H_l	Enseignement
1	thermal	8	Bruit gaussien σ = 20 sur un CAN 8 bits	5,65	IID (5,618)	4,093	Référence ; coût de la voie non IID
2	thermal-lsb	1	Bit de poids faible du même CAN	1,00	IID (0,992)	0,922	Garder les bits que le bruit fait bouger
3	ringosc-slow	1	Oscillateur, gigue de 0,5 période entre deux lectures	≈ 1	non IID (0,996)	0,861	Un seul test rejeté suffit
4	saturated	8	Gain trop fort (σ = 200), écrêtage à 0 et 255	1,93	IID (1,921)	1,727	IID mais pauvre
5	lowpass	8	Filtre du premier ordre, α = 0,95	3,97 [a]	non IID (5,626)	3,248	Sur-échantillonnage
6	ringosc-fast	1	Oscillateur lu trop vite (0,08 période par lecture)	faible	non IID (0,996)	0,110	MCV aveugle aux séries
7	biased-1bit	1	Comparateur décalé : P(1) = 1/4	0,415	IID (0,414)	0,250	Un biais compté n'est pas un défaut
8	interference	8	Sinusoïde de 40 pas, période 20, sur un bruit σ = 4	3,33 [b]	non IID (5,726)	3,430	L'estimation dépasse la vérité
9	aging	8	σ décroît de 20 à 2 le long du fichier	5,65 → 2,38	non IID (4,275)	3,381	Une moyenne n'est pas le pire cas
10	warmup	8	σ = 0,3 sur les 20 % premiers, puis σ = 20	1,00 puis 5,65	non IID (3,094)	1,019	Le démarrage plombe tout le fichier
11	drift	8	4 bits uniformes, puis 8 bits uniformes	4 puis 8	non IID (4,884)	2,440	Évaluer chaque régime
12	stuck	8	Un seul symbole (`/dev/zero`)	0	refusé (−3)	refusé (−3)	Traiter les codes d'erreur
13	replay	8	Un bloc de 4 Kio répété	≈ 0 [c]	sans verdict (−4)	$1{,}6 \times 10^{-6}$	Les tests de santé ne voient pas un rejeu
14	urandom	8	Sortie du DRBG du noyau	hors champ [d]	IID (7,882)	7,323	Plafond des estimateurs
15	urandom-4bit	4	Même sortie repliée sur 4 bits	hors champ	IID (3,972)	3,539	Plafond des estimateurs
16	urandom-1bit	1	Même sortie repliée sur 1 bit	hors champ	IID (0,994)	0,857	Plafond pour une source binaire
17	openssl	8	Sortie du DRBG d'OpenSSL	hors champ	non IID (7,896) [e]	6,638	Dispersion des estimations
18	drbg-zero-seed	8	AES-256-CTR, clé et IV nuls	0	IID (7,866)	7,145	Aucun test ne voit le déterminisme

[a] Entropie conditionnelle au passé : l'innovation du filtre a un écart-type de $20 \times \sqrt{(1 - 0{,}95^2)} = 6{,}24$. [b] La sinusoïde est déterministe : un attaquant en connaît la phase. [c] Tout le fichier contient au plus $4\,096 \times 8 = 32\,768$ bits d'entropie, ceux du premier bloc. [d] Une sortie de DRBG n'a que l'entropie de sa graine ; SP 800-90B ne s'y applique pas. [e] Faux rejet : un nouveau fichier `openssl rand` passe les trois tests.

4 Analyse des cas

4.1 Lire une sortie du lab 2

Sur une source de n bits, `test_non_iid -vv` applique les estimateurs aux symboles (« Literal ») et à la chaîne de bits (« Bitstring »). $H_{original}$ est le minimum des premiers, $H_{bitstring}$ celui des seconds, et $H_I = \min(H_{original}, n \times H_{bitstring})$. Pour le cas 1 : le plus faible estimateur littéral est le t-uplet (5,492), le plus faible sur les bits est la compression (0,5116), d'où $H_I = \min(5{,}492 ; 8 \times 0{,}5116) =$ **4,093**. Identifier l'estimateur qui fixe H_I est le premier geste du diagnostic : il dit quelle structure a été trouvée.

Tableau 3. Estimateurs les plus faibles, et ce qu'ils révèlent.

Estimateur le plus faible	Cas	Ce qu'il a trouvé
Compression (bits)	thermal, aging, drift, interference, urandom, urandom-4bit, drbg-zero-seed	Rien de précis : borne prudente, qui coûte environ 1,4 bit sur 8 à une source saine
MultiMCW (symboles)	openssl (6,638)	Une régularité locale, due au hasard
Prédicteur Lag	lowpass (3,976 sur les symboles)	La corrélation avec l'échantillon précédent
MultiMMC (bits)	lowpass (0,406 × 8 = 3,248)	Les transitions de la chaîne de bits
Plus longue répétition (LRS)	replay, warmup	Les longues séquences répétées
Compression (symboles)	biased-1bit, ringosc-fast, urandom-1bit	Les séries et le biais d'une source binaire
Collision	ringosc-slow, saturated (bits)	Les répétitions rapprochées
t-uplet	thermal-lsb	Les motifs fréquents

4.2 Sources saines : la référence (cas 1 à 3)

Cas 1, thermal. Le modèle donne 5,65 bits ; le lab 1 conclut IID avec 5,618 bits, la borne à 99 % du MCV ne coûtant que 0,03 bit. La voie non IID crédite 4,093 bits : **1,5 bit de moins, soit 27 %**, prix de l'absence d'argument IID. C'est la valeur d'un dossier physique solide : si le modèle justifie l'IID, les 5,618 bits sont crédités ; sinon, seuls 4,093 le sont.

Cas 2, thermal-lsb. Le bit de poids faible d'un bruit de $\sigma = 20$ pas est parfaitement équilibré : IID à 0,992, non IID à 0,922, au niveau d'une source binaire parfaite (cas 16 : 0,857). Par bit capturé, c'est bien plus dense que l'octet complet (4,093 / 8 = 0,51 bit par bit). Par échantillon, l'octet reste plus riche : garder les bits que le bruit fait bouger est un choix de débit, pas une obligation.

Cas 3, ringosc-slow. La phase accumule une gigue de 0,5 période entre deux lectures : la source est presque IID. Elle passe le khi-deux et la plus longue répétition, mais la statistique du nombre de séries autour de la médiane rejette l'hypothèse ($C_0 = 9\,998$ sur 10 000). Le rejet est fondé : un bit égale le précédent avec une probabilité de 0,5021 au lieu de 0,5, soit 4,2 écarts-types sur 10^6 bits, trace probable de la dérive régulière de 0,08 période par lecture. **Un seul test rejeté suffit** ; la voie non IID crédite 0,861 bit.

4.3 Défauts de conception (cas 4 à 8)

Cas 4, saturated. Un gain trop fort envoie 26 % des échantillons sur 0 et 26 % sur 255. La source reste IID (1,921 bit, pour 1,928 en théorie), mais a perdu **66 %** de l'entropie du cas 1. L'écrêtage détruit l'entropie sans

créer de dépendance : aucun test d'indépendance ne peut le signaler. Seuls l'histogramme et la comparaison au modèle le montrent. Correction : réduire le gain analogique pour que le bruit tienne dans la plage du CAN.

Cas 5, lowpass. Échantillonner plus vite que la bande passante du bruit corrèle deux échantillons voisins (α = 0,95). Les trois tests IID échouent. Le prédicteur Lag retrouve **exactement** l'entropie conditionnelle du modèle (3,976 mesurés pour 3,97), et H_I = 3,248 reste en dessous. Le MCV seul aurait donné 5,626 bits : créditer $H_{original}$ sans verdict IID aurait surestimé la source de 2,4 bits. Correction : abaisser la fréquence d'échantillonnage, ou ne garder qu'un échantillon sur k, jusqu'à ce que l'autocorrélation soit négligeable.

Cas 6, ringosc-fast. L'oscillateur avance de 0,08 période par lecture : le niveau ne change qu'environ tous les six échantillons, et un bit égale le précédent 84 fois sur 100. Les bits restent équilibrés : le MCV donne 0,996, mais la compression trouve 0,110. **La surestimation d'une voie IID indue serait d'un facteur 9.** Correction : diviser l'horloge d'échantillonnage pour que la gigue accumulée entre deux lectures couvre au moins une période.

Cas 7, biased-1bit. P(1) = 1/4 : la théorie donne $-\log_2(3/4)$ = 0,415 bit, le lab 1 conclut IID à 0,414. Un biais n'est pas un défaut s'il est compté : la graine est simplement plus longue. La voie non IID est ici très prudente (0,250, estimateur de compression) : avec 384 bits à collecter, la voie IID demande 929 échantillons et la voie non IID 1 538. Un débiaiseur (von Neumann) placé avant la capture fait partie de la source de bruit et doit être modélisé ; placé après, il n'est pas une fonction de conditionnement approuvée.

Cas 8, interference. Une sinusoïde secteur de 40 pas domine un bruit de σ = 4. Pour un attaquant qui connaît la phase, l'entropie est celle du bruit seul : **3,33 bits**. Or H_I = 3,430 : **l'estimation dépasse la vérité de 0,1 bit**, car aucun des dix estimateurs ne modélise une sinusoïde. C'est la raison d'être de la règle du minimum : H_{claim}, issu du modèle, plafonne l'estimation. Correction : découpler l'alimentation et blinder ; la composante périodique peut en outre être injectée par un attaquant.

4.4 Environnement et non-stationnarité (cas 9 à 11)

Cas 9, aging. Le bruit s'affaiblit de σ = 20 à σ = 2 le long du fichier. H_I = 3,381 est une **moyenne** : en fin de fichier, la source ne vaut plus que 2,38 bits. L'APT réglé sur 3,381 bits (W = 512, C = 85) ne déclenche en moyenne qu'en dessous d'environ 2,6 bits : entre les deux, la source livre moins que ce qui est crédité, sans alarme. Bonne pratique : qualifier sur des composants vieillis et aux extrêmes de température et de tension, un fichier par condition, et retenir le minimum.

Cas 10, warmup. Les 20 % premiers échantillons ne prennent que quatre valeurs, avec 1,00 bit. La plus longue répétition les repère et fixe H_I = 1,019 **pour tout le fichier** : la phase de démarrage a coûté 3 bits au régime établi. Bonne pratique : déterminer la durée de stabilisation, jeter ces échantillons au démarrage, capturer la campagne en régime établi, et vérifier le démarrage par le test de redémarrage.

Cas 11, drift. La loi change à mi-fichier : 4 bits uniformes, puis 8. Le pire régime vaut 4 bits ; H_I = 2,440, car les estimateurs sur les bits voient les quatre bits de poids fort à zéro dans la moitié du fichier. Le résultat est prudent mais ne décrit aucun régime réel. Bonne pratique : repérer les ruptures (moyenne et histogramme par tranche) et évaluer chaque régime séparément.

4.5 Pannes franches (cas 12 et 13)

Cas 12, stuck. Un seul symbole : les deux voies refusent le fichier avec le code `SP80090B_EALPHABET` (−3). Un code d'erreur n'est pas un résultat à 0 à interpréter plus tard : l'appelant doit arrêter la qualification. En fonctionnement, le RCT détecte cette panne en quelques échantillons.

Cas 13, replay. Un bloc de 4 Kio est relu en boucle, comme un tampon DMA qui n'est plus rafraîchi. La plus longue répétition fixe $H_I = 1{,}6 \times 10^{-6}$ bit : la panne est détectée. La voie IID échoue au khi-deux, puis le test de la plus longue répétition ne peut pas calculer sa probabilité, trop petite pour un `long double` : code `SP80090B_EINTERNAL` (−4), sans verdict (limite L1). Leçon majeure : **les tests de santé ne voient pas un rejeu**. Le bloc rejoué a l'allure de l'aléa : ni répétition consécutive pour le RCT, ni proportion anormale pour l'APT. La parade est dans la conception : compteur de trames, horodatage ou contrôle de fraîcheur du tampon.

4.6 Sorties conditionnées : le piège (cas 14 à 18)

Cas 18, drbg-zero-seed. AES-256 en mode compteur avec une clé et un IV nuls : la suite est entièrement prévisible, son entropie est nulle. Elle passe pourtant les trois tests IID avec 7,866 bits, et la voie non IID lui accorde 7,145 bits.

> **Aucun test statistique ne voit le déterminisme.** Les estimateurs mesurent la prévisibilité par des modèles simples ; un algorithme cryptographique les trompe tous. L'évaluateur doit exiger la preuve que les échantillons viennent du composant physique, en amont de toute fonction déterministe : schéma, point de capture et code d'acquisition.

Cas 14 à 16, urandom. Ces sorties de DRBG ne doivent pas être évaluées comme des sources ; elles servent de **référence d'aléa parfait** et montrent le plafond des estimateurs sur 10^6 échantillons : 7,88 bits par la voie IID et environ 7,3 par la voie non IID sur 8 bits, 3,54 sur 4 bits, 0,86 sur 1 bit. Aucune source réelle ne peut être créditée au-delà.

Cas 17, openssl. Deux leçons. D'abord, la voie IID rejette ce fichier sur la seule statistique de périodicité au décalage 8 (C_2 = 9 997) : c'est un **faux rejet**, qui arrive à environ 2 à 3 % des sources IID, et un nouveau fichier passe. La norme impose pourtant la voie non IID au fichier rejeté : relancer une capture jusqu'au succès reviendrait à choisir son résultat. Ensuite, la voie non IID donne 6,638 bits, contre 7,323 pour urandom : le prédicteur MultiMCW a trouvé une régularité locale de hasard. **Deux sources parfaites diffèrent ici de 0,7 bit** : une estimation est une variable aléatoire, et une marge sur H est prudente.

5 Redémarrage et conditionnement

5.1 Lab 3 : le test de redémarrage

Le test de redémarrage (§3.1.4) range 1 000 mises sous tension de 1 000 échantillons en matrice. Il vérifie d'abord qu'aucune valeur ne domine une ligne ou une colonne ($X_{max} \le X_{cutoff}$), puis estime l'entropie des lignes (H_r) et des colonnes (H_c) ; il faut $\min(H_r, H_c) \ge H_I / 2$.

Tableau 4. Lab 3 : test de redémarrage (1 000 × 1 000 échantillons).

Jeu	H_I (lab 2)	X_{max} / X_{cutoff}	H_r / H_c	H validée	Résultat
restart-thermal	4,093	39 / 99 : réussi	5,306 / 5,306 : réussie	**4,093**	**Qualifié**
restart-urandom	7,323	15 / 24 : réussi	7,719 / 7,354 : réussie	**7,323**	**Qualifié**
restart-warmup	4,093	1 000 / 99 : **échec**	—	0	**Rejeté**
restart-frozen	7,323	1 000 / 23 : **échec**	—	0	**Rejeté**

- **Le défaut invisible en continu.** restart-warmup a exactement la loi du cas 1 en régime établi, mais ses 20 premiers échantillons sont identiques à chaque démarrage : une colonne entière est constante (X_{max} = 1 000). Aucune capture continue ne le révèle.
- **X_{cutoff} dépend de H_I.** Plus l'entropie revendiquée est haute, plus le seuil est bas (99 pour 4,09 bits, 23 ou 24 pour 7,32 bits) ; il est simulé, d'où l'écart d'une unité à H_I égale.
- **H_I reste la borne.** H_r et H_c dépassent H_I sur les sources saines : la valeur validée reste H_I. Le test ne fait que confirmer, ou annuler, l'entropie du lab 2.
- **Bonne pratique :** de vraies mises sous tension (alimentation coupée), pas des relances logicielles ; la source doit avoir atteint l'état où elle fournira sa première graine.

5.2 Lab 4 : conditionnement et pleine entropie

Tableau 5. Lab 4 : conditionnement vers une sortie de 256 bits (n_w = 256).

Cas	n_{in}	h_{in}	h'	h_{out} (bits)	Pleine entropie
vetted-320-margin	320	320	—	$256 - 6 \times 10^{-9}$	**Oui** : marge de 64 bits
vetted-512-6.4	512	409,6	—	256	**Oui**
vetted-seed-384	3 072	384	—	256	**Oui**
vetted-thermal	632	323,3	—	256	**Oui** : 79 échantillons du cas 1
vetted-256-full	256	256	—	251,69	**Non** : pas de marge
vetted-128-short	256	128	—	128	**Non** : entrée insuffisante
nonvetted-0.99	512	409,6	0,99	253,44	**Non** : plafond $h' \times n_{out}$
nonvetted-urandom	512	409,6	0,915	234,34	**Non**
nonvetted, 4 autres	512	409,6	0,857 à 0,908	219,38 à 232,38	**Non**

- **La marge de 64 bits.** Avec une fonction approuvée (SHA-256), 256 bits d'entropie en entrée donnent 251,69 bits en sortie : les collisions de la fonction coûtent 4,3 bits. La pleine entropie exige $h_{in} \geq n_{out} + 64 = 320$ bits [3] [4].
- **Le plafond d'une fonction non approuvée.** h_{out} ne dépasse jamais $h' \times n_{out}$, h' étant l'entropie par bit mesurée sur la sortie de la fonction. Même un aléa parfait donne h' entre 0,86 et 0,92 sur 10^6 échantillons (cas 14 à 18) : une fonction non approuvée ne donne jamais la pleine entropie.
- **Du lab 2 au lab 4.** vetted-thermal convertit la mesure en nombre d'échantillons : $\lceil 320 / 4{,}093 \rceil = 79$ échantillons, soit 323,3 bits, pour une sortie SHA-256 de pleine entropie.

6 Protocole de qualification

La figure 1 ordonne les règles d'or en un protocole ; les fonctions citées sont celles de l'API (préfixe `sp80090b_`).

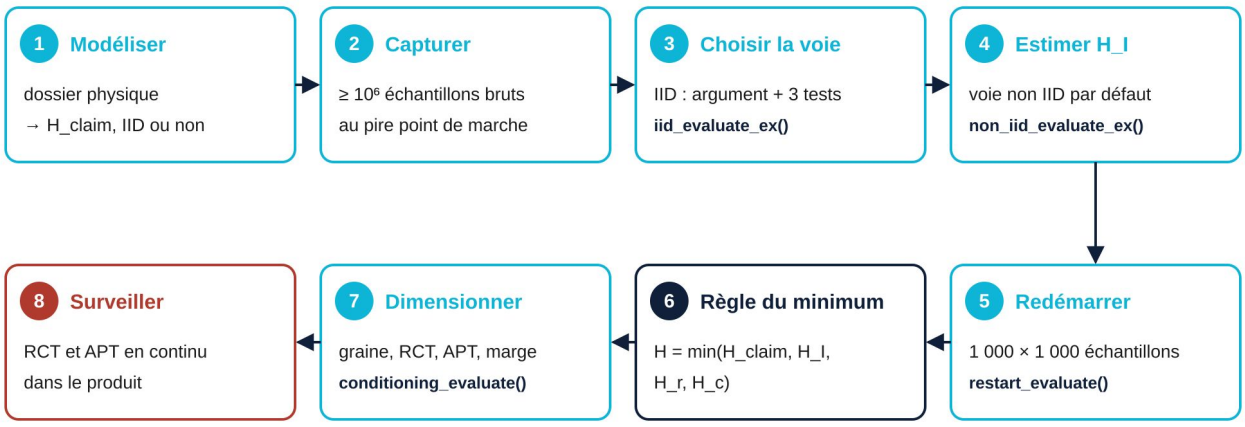


Figure 1. Protocole de qualification d'une source de bruit avec libsp80090b.

1. **Modéliser.** Décrire le phénomène physique, en déduire H_{claim} et dire si l'IID est justifiable.
2. **Capturer.** Au moins 10^6 échantillons bruts consécutifs, au point de capture documenté, pour chaque condition extrême (température, tension, vieillissement) ; jeter la phase de démarrage.
3. **Choisir la voie.** Voie IID seulement avec l'argument du modèle et les trois tests réussis sur le premier fichier ; sinon voie non IID.

4. **Estimer H_I.** Vérifier le code de retour, noter l'estimateur limitant, comparer à H_{claim} ; un écart important dans un sens ou dans l'autre remet en cause le modèle.
5. **Redémarrer.** 1 000 vraies mises sous tension × 1 000 échantillons.
6. **Appliquer la règle du minimum.** $H = \min(H_{claim}, H_I, H_r, H_c)$, sur la pire condition.
7. **Dimensionner.** Graine, seuils RCT et APT, entrée du conditionnement.
8. **Surveiller.** RCT et APT sur chaque échantillon brut, dans le produit ; au premier échec, jeter la graine en cours.

Tableau 6. Exemple complet : dimensionnement du bruit thermique (cas 1), H = 4,093 bits.

Grandeur	Calcul	Valeur
H_I (lab 2)	min(5,492 ; 8 × 0,5116)	4,093 bits
Redémarrage (lab 3)	$H_r = H_c = 5{,}306 \geq H_I / 2$	validé
H retenue	$\min(H_I, H_r, H_c)$, sans revendication IID	**4,093 bits**
RCT, seuil C	$1 + \lceil 20 / H \rceil$	**6**
APT, fenêtre et seuil	W = 512 (source non binaire), $\alpha = 2^{-20}$	**C = 59**
Graine d'un DRBG de 256 bits	$\lceil 384 / H \rceil$	**94 échantillons**
Sortie SHA-256 de pleine entropie	$\lceil (256 + 64) / H \rceil$	**79 échantillons**

La fenêtre de l'APT est de 1 024 échantillons pour une source binaire et de 512 sinon (§4.4.2). Avec une revendication IID justifiée par le modèle, H vaudrait 5,618 bits, sous réserve d'un test de redémarrage mené avec cette valeur.

7 Erreurs fréquentes

Tableau 7. Erreurs fréquentes, cas qui les démontrent et bonne pratique.

Erreur	Démontrée par	Bonne pratique
Évaluer une sortie de DRBG, de hachage ou de chiffrement	Cas 14 à 18	Capturer le bruit brut, en amont de toute fonction déterministe
Créditer $H_{original}$ sans verdict IID	Cas 5, 6, 8	$H_{original}$ n'est valable que si les trois tests réussissent ; sinon H_I
Relancer la capture jusqu'au succès IID	Cas 3, 17	Le premier fichier décide ; un rejet impose la voie non IID
Conclure à la qualité d'une source sur son verdict IID	Cas 4, 7	Comparer H au modèle, regarder l'histogramme
Croire l'estimation plutôt que le modèle	Cas 8	Plafonner par H_{claim}
Mélanger plusieurs conditions dans un fichier	Cas 9, 11	Un fichier par condition, retenir le minimum
Inclure la phase de démarrage dans la campagne	Cas 10, restart-warmup	Purger au démarrage ; test de redémarrage
Traiter un code d'erreur comme un résultat	Cas 12, 13	Arrêter et diagnostiquer
Compter sur RCT et APT pour tout détecter	Cas 9, 13	Les tests de santé détectent les pannes franches, pas un rejeu ni une dégradation lente
Conditionner sans marge	vetted-256-full	$h_{in} \geq n_{out}$ + 64 bits
Lire trois décimales comme une certitude	Cas 14, 17	Garder une marge ; plusieurs captures si possible

8 Temps de calcul

La figure 2 donne les durées mesurées par fichier de 10^6 échantillons sur un Intel Core i7-8650U (4 cœurs, 8 fils OpenMP). Trois labs se comptent en secondes ; le test 1 peut prendre une heure par fichier.

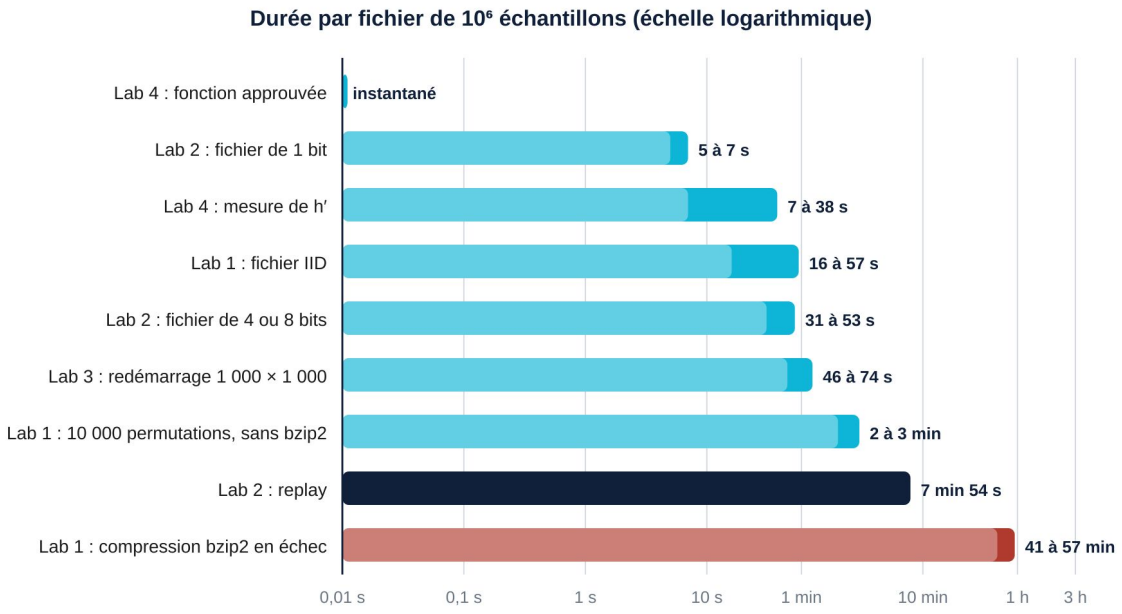


Figure 2. Durées mesurées par fichier de 10^6 échantillons (Intel Core i7-8650U, 8 fils).

8.1 Pourquoi le test 1 est long

Le test 1 (§5.1) compare 19 statistiques des données d'origine aux mêmes statistiques calculées sur **10 000 permutations** aléatoires des données. Si les échantillons sont IID, l'ordre ne compte pas et la valeur d'origine se range parmi les autres ; si elle est parmi les 6 plus grandes ou les 6 plus petites, l'hypothèse IID est rejetée. Trois facteurs font la durée :

1. **Le volume.** Chaque permutation mélange tout le fichier (10^6 échantillons) et recalcule les statistiques encore en jeu : jusqu'à 10^{10} échantillons traités par statistique.
2. **La compression bzip2.** La 19e statistique (§5.1.11) est la longueur de la compression bzip2 des valeurs écrites en décimal, soit environ 4 Mo de texte pour un fichier de 8 bits. Une compression prend 0,3 à 0,45 s sur un cœur de la machine de test : 10 000 compressions représentent à elles seules près d'une heure de calcul, l'ordre de grandeur des 41 à 57 min mesurées. Les 18 autres statistiques sont des comptages en une passe, bien moins coûteux.
3. **L'asymétrie entre réussite et échec.** Le verdict d'une statistique est acquis dès que les compteurs $C_0 + C_1$ et $C_1 + C_2$ dépassent tous deux 5 : la bibliothèque arrête alors de la calculer. Sur une source IID, cela arrive après quelques dizaines à quelques centaines de permutations. Un **échec**, lui, ne se prononce qu'au bout des 10 000 : il faut avoir vu toutes les permutations pour affirmer que la valeur d'origine reste parmi les 6 extrêmes.

Le tableau 8 le montre sur les fichiers du lab 1 : la durée dépend moins du verdict que de la statistique de compression.

Tableau 8. Lab 1 : permutations calculées et durée, par fichier.

Jeu	Verdict	Permutations (max.)	Permutations de la compression	Durée
thermal	IID	217	82	36 s
thermal-lsb	IID	3 750	16	57 s
openssl	non IID (periodicity(8))	10 000	76	moins de 3 min
ringosc-slow	non IID (numRunsMedian)	10 000	29	moins de 3 min
interference	non IID (18 statistiques)	10 000	10 000	41 min
lowpass	non IID (18 statistiques)	10 000	10 000	51 min
warmup	non IID (10 statistiques)	10 000	10 000	53 min
ringosc-fast	non IID (18 statistiques)	10 000	10 000	57 min

openssl et ringosc-slow font les 10 000 permutations, mais leur compression s'arrête avant la centième : moins de 3 min. Dès que la compression échoue, le fichier coûte près d'une heure.

8.2 Pourquoi les autres tests sont rapides

- **Test 2 (5 à 53 s).** Les dix estimateurs lisent le fichier une fois, ou trient ses suffixes une fois (plus longue répétition, t-uplet). Un fichier de 8 bits est évalué deux fois, sur les symboles puis sur les 8×10^6 bits, d'où 31 à 53 s contre 5 à 7 s pour 1 bit. Exception : replay (8 min), car les estimateurs de répétition parcourent toutes les longueurs jusqu'à la plus longue répétition, ici presque tout le fichier.
- **Test 3 (46 à 74 s).** Deux évaluations non IID (lignes et colonnes de la matrice) et la simulation de X_{cutoff}.
- **Test 4.** Une formule, instantanée, pour une fonction approuvée ; 7 à 38 s pour mesurer h′ sur la sortie d'une fonction non approuvée (une évaluation du test 2).

8.3 Conséquences pratiques

- **Commencer par le test 2.** En une minute, il donne H_l, valable dans tous les cas.
- **Ne lancer le test 1 que si le modèle revendique l'IID.** Sans revendication, la voie non IID s'applique et le test 1 est inutile ; c'est le cas par défaut de SP 800-90B.
- **Lire la durée comme un indice.** Un test 1 qui dure plus de quelques minutes a au moins une statistique non tranchée, le plus souvent la compression : le verdict sera presque toujours « non IID ». Il faut pourtant attendre la fin pour le conclure.
- **Budgéter la campagne.** Les 18 fichiers demandent 5 à 6 h au lab 1 (les six fichiers dont la compression échoue en font l'essentiel), contre un quart d'heure au lab 2 : lancer le lab 1 la nuit, un seul lab à la fois (limite C2).
- **Ne pas réduire le fichier pour gagner du temps.** La durée est proportionnelle au nombre d'échantillons, mais SP 800-90B exige au moins 10^6 échantillons (§3.1.1) ; un fichier plus court fausse les bornes de confiance.

9 Limites de l'outil à connaître

Tableau 9. Limites de libsp80090b 2.0.0 utiles à l'évaluateur.

Id	Limite	Conduite à tenir
L1	Sur une source qui rejoue un long bloc, le test de la plus longue répétition de la voie IID renvoie −4 au lieu d'un verdict	Traiter la source comme non IID ; la voie non IID donne le bon résultat (cas 13)
C2	Chaque appel lance sa propre équipe OpenMP : des évaluations simultanées sur-souscrivent le processeur	Lancer un lab à la fois, ou fixer `OMP_NUM_THREADS`
M2	Quelques allocations des estimateurs MultiMMC et LZ78Y et du khi-deux ne sont pas vérifiées	Prévoir la mémoire nécessaire ; un arrêt brutal signale un manque de mémoire

10 Conclusion

Les 18 cas montrent ce que les tests de SP 800-90B savent faire : détecter les dépendances (cas 3, 5, 6, 8), les ruptures de loi (cas 9 à 11), les répétitions (cas 13) et les sources mortes (cas 12), et chiffrer prudemment l'entropie restante. Ils montrent aussi ce qu'ils ne savent pas faire : voir le déterminisme (cas 18), juger la qualité d'une source IID (cas 4), garantir une valeur supérieure à la vérité (cas 8) ou décrire le pire cas d'un fichier qui mélange des régimes (cas 9).

libsp80090b fournit les mesures ; la sécurité vient de la démarche qui les entoure : un modèle physique, une capture au bon endroit et au pire point de fonctionnement, un test de redémarrage, la règle du minimum et des tests de santé réglés sur la valeur retenue. Cette démarche prépare un dossier ESV [5] ; elle ne remplace pas l'évaluation du NIST.

11 Références

[1] M. Sönmez Turan, E. Barker, J. Kelsey, K. McKay, M. Baish, M. Boyle. *Recommendation for the Entropy Sources Used for Random Bit Generation*. NIST SP 800-90B, janvier 2018.

[3] E. Barker, J. Kelsey, K. McKay, A. Roginsky, M. Sönmez Turan. *Recommendation for Random Bit Generator (RBG) Constructions*. NIST SP 800-90C, septembre 2025.

[4] National Institute of Standards and Technology. *Security Requirements for Cryptographic Modules*. FIPS PUB 140-3, 2019 ; Implementation Guidance, D.K.

[5] NIST CMVP. *Entropy Source Validation (ESV) Program*. Documentation du programme ESV.

[7] J. Kelsey, K. A. McKay, M. Sönmez Turan. *Predictive Models for Min-Entropy Estimation*. CHES 2015, LNCS 9293.

Les numéros de référence sont ceux de la note NT-01.